

Agent eBPF Filter

面向 AI Agent 的 内核级运行时安全与可观测平台

让 Agent 的“承诺”和操作系统里的“事实”对齐起来

eBPF 内核事实

BPF LSM 同步阻断

Execution Graph 执行归因

负责人 / 学院 / 联系方式:

【待填】

推荐学院: 【待填】

负责人: 【待填】

手机号 / QQ: 【待填】

一句话定位

Agent 运行时证据链与策略边界

84%

AI 开发工具采用意愿

28.65M

public GitHub 新增硬编码密钥

OS

内核级事实采集与阻断

路演结构：从真实痛点到代码证据，再到商业落地

按高校项目路演常用逻辑组织：背景痛点、解决方案、创新性、可行性、落地价值。



展演节奏建议：前 2 分钟交代外部证据，中间 5 分钟集中讲原型和演示，最后 2 分钟说明落地路径与资源诉求。

数据证据： AI Agent 不是未来风险，而是当前安全缺口

采用公开调研与安全报告，说明市场使用率、泄露规模、治理缺口和经济成本。

84%

Stack Overflow：正在使用或计划使用 AI 开发工具

28.65M

GitGuardian：2025 年 public GitHub 新增硬编码密钥

\$4.44M

IBM：全球平均数据泄露成本

97%

IBM：AI 相关事件组织缺少适当 AI 访问控制

24,008

GitGuardian：公开 MCP 配置中暴露的唯一密钥

Sentiment and usage / All Respondents

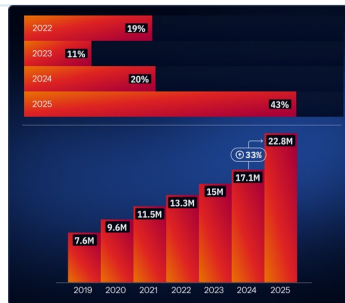
AI tools in the development process



2025
Developer
Survey

Source: survey.stackoverflow.co/2025
Data licensed under Open Database License (ODbL)

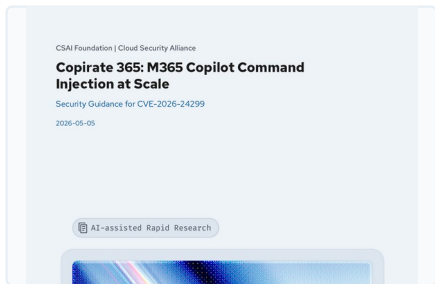
采用率提升叠加信任下降：Agent 一旦接入终端和文件系统，必须用运行时事实建立审计边界。



软件生产提速：public commits 与开发者规模同步增长，密钥与配置治理需要跟上生成速度。

真实案例：工具误用、密钥外泄、Copilot 数据外泄已形成样本

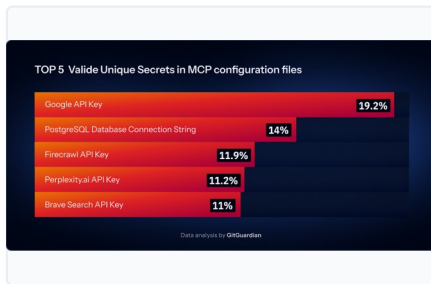
用报告截图替代概念化图标，降低生成感，同时让评委能追溯外部证据。



M365 Copilot 信息泄露

CSA 研究梳理 12 个月内多起 Copilot 相关披露；EchoLeak CVSS 9.3，体现上下文边界问题。

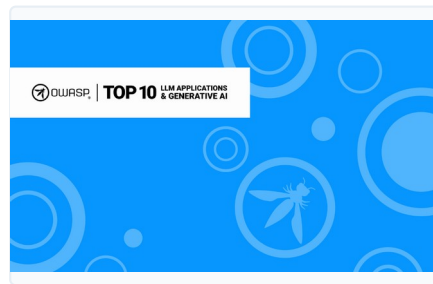
需要 runtime 证据链



MCP 配置密钥泄露

GitGuardian 发现 24,008 个 MCP 相关唯一密钥，其中 2,117 个仍有效；配置本身成为攻击面。

需要 runtime 证据链



Agentic Tool Misuse

OWASP 将工具误用、权限滥用、不可追踪列为核心风险，强调日志、沙箱和实时边界。

需要 runtime 证据链

问题：Agent 安全已从“回答错”变成“三个不可见”

编码 Agent 会启动终端、改文件、装依赖、访问网络，安全边界必须落到运行时。

意图不可见

- EDR 看得到进程，却不知道哪个 run/task/tool_call 触发
- Prompt 网关看得到文本，看不到 OS 行为
- 审计口径无法对齐“承诺”与“事实”

链路不可见

- 危险动作常发生在 shell、python、node、git、npm、curl 子进程
- MCP、skills、依赖脚本扩大本机攻击面
- 父子进程上下文容易丢失

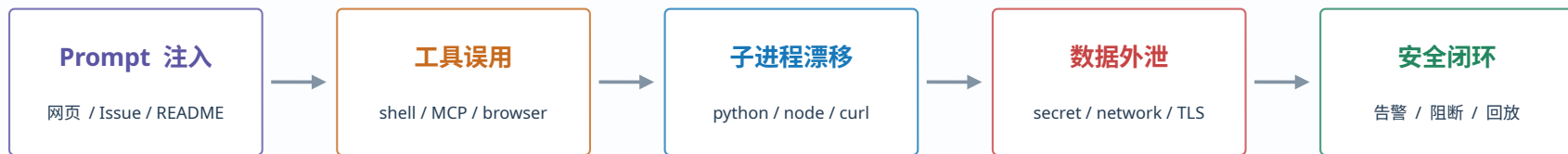
阻断不可见

- 事后日志难证明动作是否已被内核拒绝
- UI 标红不等于 OS 层真实拒绝
- 安全团队需要可回放证据链

结论：评委真正需要看到的不是“再加一个大屏”，而是把 Agent 语义与操作系统事实合成可验证、可阻断、可复盘的证据链。

典型风险链：Prompt 注入 → 工具误用 → 子进程漂移 → 数据外泄

项目从执行链而不是单条日志看待 Agent 风险。



观测对象

进程、文件、网络、策略、工具调用

判断依据

意图是否与事实行为一致

处置动作

ALLOW / ALERT / BLOCK / REWRITE

与案例的对应关系：EchoLeak 证明“外部输入可驱动内部数据泄露”；MCP 密钥证明“配置即攻击面”；GitGuardian 数据证明“AI 辅助编码让密钥泄露速度提升”。

解决方案：看得见、说得清、拦得住、可复盘

以 eBPF 为事实底座，用 hooks/wrapper 补齐 Agent 语义，再进入图谱和策略闭环。

Agent / CLI

Codex、Claude、Gemini、Copilot、脚本与子进程

语义层

wrapper / native hooks / adapters：run、task、tool_call、intent

事实层

eBPF tracepoints / cgroup / BPF LSM：exec、file、net、fork

策略层

BPF LSM、cgroup、wrapper：ALLOW / ALERT / BLOCK / REWRITE

证据层

EventEnvelope、semantic_alerts、Execution Graph、JSONL、OTLP

核心差异：不是替代模型安全，而是在模型调用工具后，用操作系统事实证明它实际做了什么，并在危险动作发生前拦截。

当前原型：已不是概念图，而是可运行工程

仓库包含 Go 后端、eBPF 程序、Vue 前端、wrapper、适配器与部署脚本。

Go 后端

特权 runtime / HTTP+WS API / hook

```
backend/main.go  
backend/event_envelope.go  
backend/semantic_alerts.go  
backend/execution_graph.go
```

eBPF 内核

tracepoints / BPF LSM / cgroup 网络

```
backend/ebpf/agent_tracker.c  
backend/ebpf/lsm_enforcer.c  
backend/ebpf/  
cgroup_sandbox.c
```

Vue 前端

Dashboard / Execution Graph / Config

```
frontend/src/views/  
Dashboard.vue  
frontend/src/views/  
ExecutionGraph.vue  
frontend/src/views/Config.vue  
frontend/src/views/Plugins.vue
```

部署与验证

systemd / rc.local / K8s / smoke test

```
Makefile install/uninstall  
scripts/os-enforcement-  
smoke.sh  
docs/kubernetes.md  
deploy/kubernetes/*.yaml
```

答辩要点：每个卖点都能指到代码文件、演示页面和验证脚本，避免只停留在概念图。

创新一： BPF LSM + cgroup 形成确定性内核阻断

不是只做事后日志，而是在 `exec/open/read/write/mmap/rename/connect` 等路径前置决策。

BPF LSM

- `bprm_check_security`：执行前检查
- `file_open / file_permission`：打开与读写
- `inode_*`：创建、删除、重命名、链接
- 命中策略返回 `-EACCES`

cgroup 网络

- `connect4/connect6`
- `sendmsg4/sendmsg6`
- 按 `cgroup`、`IP`、`IPv6`、端口阻断
- 覆盖 `TCP/UDP` 外联场景

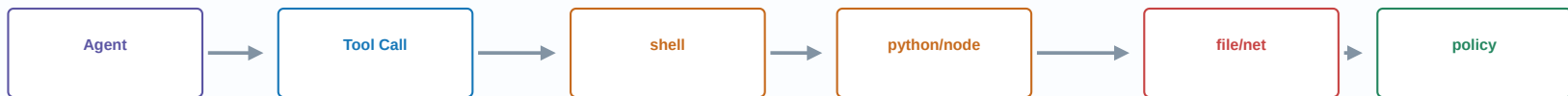
策略原则

- 确定性 `map lookup`
- `ML/LLM` 只建议，不直接内核阻断
- 策略通过认证 `API` 修改
- 阻断证据进入执行图谱

评委可感知亮点：真实 OS 级拒绝，而不是 UI 上标红。代码证据：`backend/ebpf/lsm_enforcer.c`；`backend/ebpf/cgroup_sandbox.c`；`scripts/os-enforcement-smoke.sh`。

创新二：进程树追踪让 Agent 子进程不再“失踪”

真实 Agent 行为经常发生在 /bin/sh、python、node、git、npm、curl 等子进程。



继承字段

agent_run_id / task_id / tool_call_id /
trace_id

事实字段

PID/TGID/PPID、comm、cwd、
cgroup_id

复盘结果

一条链路回放所有子进程与对象

创新三：语义 - 事实一致性检测

把工具声明的意图与 eBPF 事实对比，识别“说是读文件，实际在外联 / 读密钥”。



示例：任务声明为只读代码审查，但子进程访问 ~/.ssh 或向未知公网地址发送数据 → 触发高风险告警 / 阻断。

演示场景：三分钟证明“看得见、说得清、拦得住”

现场优先展示硬核闭环，避免只展示静态大屏。

00:00

敏感路径

Agent 尝试读取 .env / ssh key → SECRET_ACCESS + 任务归因

00:50

异常外联

curl / python 子进程连接未知 IP:port → UNEXPECTED_NETWORK_EGRESS

01:40

内核阻断

BPF LSM 返回 EACCES，cgroup 拒绝 connect/sendmsg

02:30

图谱回放

Agent Run → Tool Call → Process → File/Network → Policy

答辩话术：我们不是只做可视化，而是在内核执行路径上获取证据并形成策略闭环。

与评审规则对齐：四个维度逐项回应

高教主赛道创意组重点：个人成长 30、项目创新 30、产业价值 25、团队协作 15。

个人成长 30

课程知识到 eBPF 原型；调研 Agent 安全真实问题；专创融合。

项目创新 30

BPF LSM、内核态阻断、进程树、语义 - 事实一致性。

产业价值 25

AI coding 团队、高校实验室、企业安全审计强需求。

团队协作 15

内核、后端、前端、算法、商业分工清晰。

规则依据：2025 高教主赛道创意组评审规则；2026 正式通知发布后需复核。

目标市场： AI Agent 落地越快，运行时安全越刚需

从教育科研切入，扩展到 AI coding 团队和企业私有化部署。



风险信号

GitGuardian： AI service secrets 2025 年达到 1,275,105，YoY +81%； AI 辅助提交泄露率高于全站基线。

高校实验室

eBPF/AI 安全教学
课程实验与竞赛
软著 / 论文 / 项目成果

AI coding 团队

本地 / 云端 Agent 审计
敏感文件与外联治理
团队策略模板

企业安全

私有化部署
审计报表与 SIEM
合规留存

打法：先低门槛开源获客，再用专业版 / 私有化 / 培训完成转化。

商业模式：开源核心 + 专业版 + 私有化 + 教育服务

保留技术影响力，同时形成可收费的团队、企业与教学版本。

版本	价格	核心价值
Community	免费 / 开源	单机观测、基础告警、教学实验
Team Pro	3.98 万 / 年起	团队策略、报表 / 训练样本、多用户
Enterprise	19.8 万 / 年起	私有化 / 多节点、SSO、审计留存、SIEM
Education Kit	3 万 / 套起	课程实验、靶场、竞赛训练营
Consulting	5-20 万 / 项目	PoC、红队 replay、策略调优

注：价格为校赛版测算，提交前建议用真实客户访谈、试点意向或合同报价校准。

实施路线：把原型做成可验证产品

围绕竞赛、试点、知识产权和商业化四条线推进。



阶段目标都对应可验收证据：脚本结果、演示录屏、试点反馈、知识产权材料和可复现 benchmark。

团队分工与合规边界：高权限工具必须讲清楚

提交前将【待填】替换为真实姓名、学号、年级、学院与贡献证据。

团队分工

负责人：【待填】总体架构 / 答辩 / 进度
eBPF：【待填】LSM / cgroup / tracepoints
后端：【待填】Go API / EventEnvelope / 策略
前端：【待填】Vue / 执行图谱 / 低代码
算法评测：【待填】ML / replay
商业调研：【待填】客户访谈 / 财务

权限与隐私

- 后端加载 eBPF，保持 root/ 特权边界
- 写 API、shell、策略变更均有 token 与 runtime gate
- TLS 明文捕获默认关闭
- 事件流只保留摘要 / 长度 / 角色 / 厂商

误报与合规

- 先观察模式再阻断
- 回放 benchmark 调优
- ML/LLM 建议需人工确认
- 用于本地 / 授权环境，不采集未授权数据
- 演示数据必须脱敏

团队证明建议：commit 记录、模块负责人截图、导师指导记录、测试报告、软著 / 论文 / 专利分工。

总结：让 AI Agent 可观测、可解释、可回放、可控制

用公开数据说明刚需，用真实工程证明可行，用可复盘演示争取支持。

证明 1：真实需求

Stack Overflow、GitGuardian、IBM 数据说明 AI 开发工具普及、密钥泄露和治理缺口已经同时出现。

证明 2：真实风险

EchoLeak、MCP Tool Poisoning、Copilot 信息泄露案例说明工具链和上下文边界已是攻击面。

证明 3：真实原型

eBPF + BPF LSM/cgroup + hooks/wrapper + Execution Graph，形成可演示、可验证闭环。

需要支持：导师 / 学院资源、试点用户、软著 / 专利指导。目标：校赛晋级、省赛打磨、形成可转化产品。

主要来源：Stack Overflow Developer Survey 2025；GitGuardian State of Secrets Sprawl 2026；IBM Cost of a Data Breach Report 2025；OWASP Top 10 for LLM Applications / Agentic AI Threats；CSA M365 Copilot CVE-2026-24299 research note；NVD CVE-2025-32711。

谢谢各位老师，请批评指正